

# PASSWORD AND AUTHENTICATION POLICY

Version 1.0

Revision Date: August 18, 2026

Contact: [security@prompthalo.com](mailto:security@prompthalo.com)



## DOCUMENT INFORMATION

|                  |                                                    |
|------------------|----------------------------------------------------|
| Document Family  | Governance, Ethics, and Security                   |
| Document Title   | Password and Authentication Policy                 |
| Document ID      | POL-PWD-001                                        |
| Current Version  | 1.0                                                |
| Approved Date    | August 18, 2026                                    |
| Approved By      | Information Security Steering Committee            |
| Effective Date   | August 18, 2026                                    |
| Next Review Date | August 18, 2027                                    |
| Classification   | Internal                                           |
| Document Owner   | Chief Executive Officer — Accountable Party        |
| Prepared By      | Security Officer                                   |
| Review Cycle     | Annual, or upon material change                    |
| Supersedes       | N/A                                                |
| Audience         | All personnel, including employees and contractors |

## APPROVERS AND OWNERS

| Name             | Role           | Information Security Role        | Signature | Date            |
|------------------|----------------|----------------------------------|-----------|-----------------|
| Madhuri Chandoor | Approver       | CEO and Founder                  |           | August 18, 2026 |
| Praveen Sharma   | Owner / Author | Fractional CISO/Security Officer |           | August 18, 2026 |

## COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria CC6.1 and CC6.3, and GDPR Article 32. It follows current national guidance rather than the composition-and-rotation rules that guidance has withdrawn.

## DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE .....5

2 SCOPE .....5

3 ROLES AND DEFINITIONS.....5

4 TERMINOLOGY .....5

5 AUTHENTICATION.....6

6 PASSWORDS .....6

7 LOCKOUT, RECOVERY AND COMPROMISE .....6

8 RECORDS.....7

9 EXCEPTIONS .....7

10 REFERENCE.....7

11 DOCUMENT POLICY HISTORY.....7

## 1 Overview and Purpose

---

PromptHalo Technologies (“the Company”) authenticates people through Google Workspace and keeps shared secrets in a password manager. This Policy says what is required of both.

It follows current national guidance: length and breach screening rather than forced complexity and rotation. Rules that push people toward predictable passwords and sticky notes make things worse, which is why the guidance changed.

## 2 Scope

---

This Policy covers authentication to Company systems by people and by non-human identities. Where a system authenticates through the identity provider, that provider's settings are the control and nothing separate is configured.

## 3 Roles and Definitions

---

1. "The Company" refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

## 4 Terminology

---

The following terms have the meanings given below wherever they appear in this policy.

1. **Accountable Party** — the CEO or, in their absence, the Security Officer, who owns this policy.
2. **Breach screening** — checking a proposed password against known breached-password lists.
3. **Confidential information** — information classified Confidential or Restricted under the Data Classification Policy, including customer data.
4. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.
5. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
6. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. [SOC 2: CC1.2, CC1.3]
7. **Passkey** — a phishing-resistant credential bound to a device, which replaces a password rather than supplementing it.

8. **Personnel** — employees, officers, contractors, consultants, interns and temporary workers of the Company.
9. **Phishing-resistant factor** — a second factor that cannot be relayed by an attacker, such as a hardware key or a passkey.
10. **Security Officer** — the individual accountable for day-to-day operation of the security program.
11. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.
12. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

## 5 Authentication

1. Multi-factor authentication is enforced for every person on every system in scope. [SOC 2: CC6.1]
2. Phishing-resistant factors — passkeys or hardware keys — are used for administrative access to AWS, Google Workspace and GitHub, and for the password manager itself. [SOC 2: CC6.1, CC6.3]
3. People authenticate through the identity provider, and applications use single sign-on wherever they support it, so that one suspension removes access in most places at once. [SOC 2: CC6.1]

## 6 Passwords

1. Passwords are long rather than complex: a minimum length with no forced composition rules, screened against known breached passwords, and not rotated on a schedule. They are changed when there is reason to believe they are compromised. [SOC 2: CC6.1]
2. Passwords are not reused between Company and personal accounts and are not shared. Where a secret genuinely must be shared, it goes through the password manager rather than a message. [SOC 2: CC6.1, CC6.7]
3. Non-human identities use keys, tokens or roles rather than passwords, held in a managed secrets service and retrieved at runtime. [SOC 2: CC6.1, CC6.7]
4. Shared secrets live in the Company password manager, which every person uses. A secret that has been sent through chat or email is treated as compromised and rotated, because it cannot be unsent. [SOC 2: CC6.1, CC6.7]

## 7 Lockout, Recovery and Compromise

The two moments an attacker looks for are a locked account and a forgotten password, because both invite someone to be helpful.

1. Repeated failed sign-in attempts lock the account, and the identity provider's own throttling and suspicious-sign-in protections are left enabled rather than tuned down because they are inconvenient. [SOC 2: CC6.1]

2. Account recovery does not bypass multi-factor authentication. Recovery is performed by an administrator after confirming identity through a channel other than the one being recovered — not by email alone, and not on the strength of a message that sounds like a colleague. [SOC 2: CC6.1, CC6.2]
3. Recovery codes are held in the password manager rather than printed or stored on a device, and are regenerated after use. [SOC 2: CC6.1]
4. Where a credential may have been exposed — a phishing page entered, a secret pasted into the wrong window, a device lost — it is reported the same day and rotated. Reporting quickly is treated as doing the right thing; the credential is replaced either way. [SOC 2: CC6.1, CC7.4]

## 8 Records

1. Identity provider settings evidencing multi-factor enforcement and the factor types allowed. [SOC 2: CC6.1]
2. Password manager configuration and membership. [SOC 2: CC6.1]
3. Break-glass credential arrangements, under the Access Control Policy. [SOC 2: CC6.3]

## 9 Exceptions

Where a system cannot support multi-factor authentication or federation, the position is recorded by the Accountable Party with the compensating measure and a review date. Where no exceptions are in force, that is recorded affirmatively at the annual review.

## 10 Reference

1. SOC 2 Trust Services Criteria, Security category [CC6.1, CC6.3]
2. POL-AC-001 Access Control Policy [SOC 2: CC6.1, CC6.3]
3. POL-ISP-001 Information Security Policy [SOC 2: CC5.3]
4. POL-ENC-001 Encryption Policy [SOC 2: CC6.7]
5. NIST SP 800-63B Digital Identity Guidelines
6. EU General Data Protection Regulation, Article 32

## 11 Document Policy History

| Version | Date            | Description            |
|---------|-----------------|------------------------|
| 1.0     | August 18, 2026 | Initial policy release |